

Lumina Global Enterprise Security & Compliance Policy (2026)

Document ID: POL-SEC-2026-V4 | Effective Date: January 1, 2026 | Classification: Enterprise Confidential

1. Data Classification Hierarchy

All enterprise information assets are categorized into four strict classification tiers: **Public** (unrestricted disclosure), **Internal** (company personnel only), **Confidential** (departmental or project-restricted access), and **Restricted** (customer PII, financial credentials, cryptographic master keys, and proprietary source code). Access to Restricted assets is governed by Zero-Trust role-based access control (RBAC) and just-in-time privilege elevation.

2. Remote Work & Mobile Device Policies

Corporate devices accessing Internal or Confidential networks must maintain full-disk AES-256 encryption, active endpoint detection and response (EDR), and enforce a maximum 5-minute screen lock timeout. Personal devices (BYOD) are strictly prohibited from storing or caching Restricted data locally without an enterprise-managed enclave container.

3. Tier-3 Jurisdiction Exceptions & Compliance Rules

Section 3.4 (Tier-3 Jurisdiction Special Access Exception): Under standard operating procedures, access to Restricted data from personal devices within Tier-3 sovereign jurisdictions is strictly forbidden. However, an emergency exception may be granted under the following exact circumstances: (1) An active Severity 1 production incident requires immediate subject-matter expertise unavailable in other jurisdictions; (2) The employee has obtained prior written authorization from both the **VP of Engineering** and the **Chief Information Security Officer (CISO)**; (3) The device connects exclusively through an isolated zero-trust cloud bastion session using a mandatory FIPS 140-2 Level 3 hardware security key (hardware token) with biometric confirmation; and (4) All session activity is logged to an immutable audit trail with dual-custody verification.

4. Cryptographic Key Management Lifecycle

Key Class	Mandatory Rotation Schedule	Deprovisioning Grace Period	Storage Requirement
Root Encryption Keys (REK)	Every 90 Days	72 Hours Maximum (Cryptographic S/H)	FIPS 140-3 Hardware HSM
Data Encryption Keys (DEK)	Every 30 Days	48 Hours Grace Period	Encrypted by REK in Cloud KMS
Ephemeral Session Keys	Every 1 Hour (60 Minutes)	Immediate Revocation on Terminate	Volatile Memory Only (Zeroized)
API Service Account Tokens	Every 180 Days	24 Hours Dual-Active Window	Encrypted Secret Store with RBAC

5. Incident Governance & Escalation Timelines

Enterprise incidents are classified across three operational tiers requiring structured escalation:

- Severity 3 (Minor Degradation):** Standard business hours response. Team Lead must be notified within 4 hours. Resolution target is 2 business days.
- Severity 2 (Service Impairment / High Risk):** 24/7 on-call response. Engineering Manager must be notified within 1 hour. Automated health alerts dispatch to primary triage team.
- Severity 1 (Critical Outage / Active Breach):** Immediate emergency mobilization. Both the **SecOps Lead** and the **On-Call VP** must be notified within **15 minutes** of detection. An emergency cross-functional war room is established

immediately with hourly status broadcasts.